IT & Information Security Policy

Acceptable use of company devices and systems, passwords, MFA, client data handling and incident reporting.

Document ID	Version	Effective date	Policy owner	Applies to
ERX-HR-009	2.2	01 Jan 2026	IT & Admin	All employees and contractors with system access

1. Company equipment

- Every employee receives a company laptop on day one, configured by IT with antivirus, disk encryption and device management.
- Laptops are replaced every 3 years. Lost or stolen devices must be reported to IT within 2 hours and to police within 24 hours.
- Damage caused by negligence may be charged to the employee, up to SAR 1,500.
- Do not install unlicensed software. Request software through the IT Helpdesk in Odoo.

2. Accounts and passwords

- Passwords must be at least 12 characters with a mix of letters, numbers and symbols, and changed every 180 days.
- Multi-factor authentication (MFA) is mandatory for email, Teams, Odoo, GitHub and VPN.
- Never share passwords. Use the company password manager (Bitwarden) for client credentials.
- Forgot password: use self-service reset on the login page, or call IT ext. 2200.

3. Client data handling

- Client production databases may only be accessed with the client's written approval and through the approved bastion/VPN.
- Use anonymised or test copies for development. Never download production data to a personal device or personal cloud.
- Personal data must be handled according to the Saudi Personal Data Protection Law (PDPL) and the client contract.
- Delete client data copies within 30 days after project closure and confirm in the project closure checklist.

4. Email and internet

- Company email is for business use; limited personal use is acceptable.
- Forwarding work email to personal accounts is prohibited.
- Use of AI tools: only approved AI tools may be used with company information; never paste client confidential data or source code into public AI tools.

5. Phishing and incidents

- Report suspicious emails with the 'Report Phishing' button in Outlook.
- Report any security incident (lost device, suspected breach, malware, wrong recipient email with client data) immediately to security@erpoxa.com or ext. 2211. Early reporting is never punished.
- Mandatory security awareness training every 6 months.

6. Source code

All code written for Erpoxa or clients is company or client intellectual property. Code is stored only in company GitHub organisation repositories with branch protection. Personal repositories must not contain company code.

7. Monitoring

Erpoxa may monitor company systems and devices for security and compliance purposes, in line with applicable law. Employees should not expect privacy on company systems.